Guardrails

Every guardrail, where it lives, and the test that proves it **blocks** the bad path. "Live" = observed on the deployed system with real Gmail / Retell / Rocketlane / Slack. Evals = real-Claude datasets (`make eval`).

Required by the assignment (Part 3)

#	Guardrail	Where	Proof
G1	**All required fields present and valid before anything happens**: customer name, contact email, AE, Salesforce opportunity link (`*.salesforce.com` / `*.force.com` , id `006…`). Missing / malformed / conflicting → threaded Gmail reply to the AE listing exactly what's missing; nothing is created and no call is placed.	`guardrails/input.py` , `graph/intake.py` (`validate` , `request_clarification`)	`test_missing_required_field_asks_ae_and_does_nothing_else` , `test_each_missing_required_field_is_reported` , `test_malformed_contact_email_asks_for_clarification` , `test_missing_opportunity_link_is_reported` , `test_whitespace_only_name_counts_as_missing` ; evals: extraction 26/26 (missing-field and malformed cases)
G2	**No project without a clear, confirmed tier from the AE call.** Confirmed only if Retell's analysis says enterprise/growth **and** the AE explicitly confirmed the read-back **and** an independent LLM transcript reading agrees. No answer, voicemail, IVR, hedging, wrong person, stale webhook → retry (max 3) → human escalation.	`guardrails/decision.py` (`decide_tier` , `CallResult` with `StrictBool`), `graph/intake.py`	`test_persistently_ambiguous_answers_escalate_and_never_guess_a_tier` , `test_ae_never_answers_retries_three_times_then_escalates` , `test_tier_without_explicit_confirmation_is_unclear` , `test_cross_check_disagreement_is_unclear` , `test_not_connected_is_no_answer_and_never_a_tier` , `test_call_result_for_a_different_call_id_is_rejected` ; evals: transcripts 24/24, **false-confirmed 0** (Haiku and Sonnet); live: Enterprise confirmed by phone
G3	**Every action logged** with timestamp, agent, step, input, output, decision rationale and status; phone numbers masked; every LLM call logs model, prompt version, tokens, latency, cost.	`services/audit.py` , `tools/registry.py` , `llm/client.py`	`test_every_step_is_audited_with_timestamp_and_rationale` , `test_phone_masking_keeps_last_four` ; live: 20-step audit trail of the first real run (dashboard → Activity)

Additional guardrails

Input and identity

#	Guardrail	Where	Proof
G4	Sender must be an **active AE** in the Postgres directory, checked before any LLM call or reply.	`graph/intake.py` `check_sender`	`test_unknown_sender_is_stopped_before_any_llm_call_or_reply` , `test_sender_not_in_ae_directory_escalates_without_calling`
G5	**Anti-spoofing**: Gmail's own `Authentication-`	`providers/real/gmail.py` `sender_auth`	`test_unauthenticated_email_from_real_ae_address_escalates_before_any_side_effec` `test_to_inbound_uses_topmost_gmail_header_and_ignores_arc_and_spoofed_ones` ,

#	Guardrail	Where	Proof
	`Results` (`mx.google.com` , top-most only) must show `dmarc=pass` or aligned `dkim=pass` ; SPF alone never counts.		`test_malformed_or_smuggled_verdicts_do_not_authenticate` ; live: real inbox mail authenticates
G6	**Prompt injection**: emails, transcripts and task data are untrusted data in every prompt; injected instructions are never followed or echoed.	`llm/prompts/*`	evals: extraction injection cases, transcript injection cases
G7	One deal per email; auto-replies never start a run.	`guardrails/input.py` , gmail provider	`test_duplicate_gmail_notification_creates_one_run` , extraction `multi_deal` evals

Decisions and actions

#	Guardrail	Where	Proof
G8	**Duplicate onboarding** blocked by normalised customer name + 15-char Salesforce id, locally and in Rocketlane, **before the call and again before the create**.	`graph/intake.py` `precheck_duplicate` , `check_duplicate`	`test_human_set_tier_still_runs_duplicate_check` , idempotency audit tests
G9	**Tool allowlists**: each agent (intake, comms, tracking, migration) can only call its own tools; inputs validated by pydantic.	`tools/definitions.py` , `tools/registry.py`	`test_agents_have_disjoint_least_privilege_allowlists` , `test_allowlist_violation_inside_graph_marks_run_failed`
G10	**Human resolutions are constrained by escalation kind**: `set_tier` only for tier escalations and never after a project exists; resolving a non-escalated run is rejected.	`graph/root.py` `ALLOWED` , `validate_resolution`	`test_set_tier_on_a_non_tier_escalation_does_not_create_a_project` , `test_set_tier_after_project_exists_cannot_desync_slack_from_project` , `test_resolve_on_a_run_that_is_not_escalated_is_rejected`
G11	**Idempotency**: keys reserved before every side effect; an interrupted write is reconciled by lookup or escalated, never blindly repeated (one call per attempt, one project, one channel, one welcome, one reply).	`tools/registry.py` , providers	`tests/test_idempotency_audit.py` , `test_rocketlane_timeout_after_accepting_create_does_not_duplicate` , `test_crash_mid_slack_setup_resumes_from_checkpoint_without_duplicates`
G12	**Stuck runs** (crash mid-step) are escalated, not left silent.	`main.py` `tick()`	`tests/test_recovery.py`

Output

#	Guardrail	Where	Proof
G13	**Welcome message fact-checked in code**: customer name, tier, duration, CSM model; no prices, dates or invented commitments; one redraft, then a static template.	`guardrails/output.py` `check_welcome`, `graph/comms.py`	`test_welcome_with_invented_date_or_price_is_rejected`, `test_welcome_with_wrong_duration_fails`, `test_bad_llm_welcome_falls_back_to_static_template`; evals: welcome 8/8
G14	**Handoff summary fact-checked**: no invented dates, people or prices; must not contradict the migration result or the tier; never posted to the customer-shared channel.	`guardrails/output.py` `check_handoff`, `services/tracking.py`	`tests/test_tracking.py`, `tests/test_tracking_review.py`; evals: handoff 6/6 (Sonnet)
G15	Nothing internal (Salesforce link, escalations, migration defects, handoff, prices) goes into the customer-shared Slack channel: only Agent 2 can post there, every update passes `check_customer_message`, and Agent 3's only Slack tool refuses customer channels.	`services/customer_comms.py`, `guardrails/output.py`, `tools/definitions.py`	`test_phase_progress_is_posted_by_the_communication_agent`, `test_internal_post_tool_refuses_any_customer_channel`, `test_customer_message_guard_blocks_internal_content`; live: `make e2e-tracking` 12/12

Data migration (Priya's "marked done but not verified")

#	Guardrail	Where	Proof
G16	Five code checks (count, missing PKs, duplicates, required fields, missing columns) on real SQL tables whose schemas differ; evidence written to the "Migration verified" task; **the agent never completes the task**.	`services/migration_check.py`	`test_all_pass_writes_evidence_note_and_leaves_task_open`, `test_failure_escalates_to_csm_writes_evidence_and_leaves_task_open`, `test_append_note_keeps_existing_note_and_never_sends_status`, `test_column_missing_in_destination_fails_and_extra_columns_pass`, `test_seeded_demo_data_catches_every_planted_defect`; live: evidence note written, task stayed "To do"
G17	"Migration verified" ticked without a passing check (or CSM acceptance) → **reopened** and escalated; handoff blocked until migration is resolved.	`services/tracking.py`	`tests/test_tracking.py`, `tests/test_tracking_review.py`

Platform

#	Guardrail	Where	Proof
G18	Webhooks authenticate themselves: Retell HMAC signature (±5	`main.py`, `providers/real/retell.py`	`test_voice_webhook_bad_signature_is_rejected_and_ignored`, `test_gmail_push_with_bad_token_is_rejected`, `test_duplicate_and_stale_voice_events_are_ignored`

#	Guardrail	Where	Proof
	min), Gmail push token.		
G19	Everything except `/webhooks/*`, `/healthz` and the login page behind the in-app login (session cookie, CSRF origin check, login rate limit, fail closed without a password); secrets never logged (push token and auth headers redacted, phones masked).	`app/auth.py`, `deploy/Caddyfile`, `app/jsonlog.py`	`tests/test_auth.py`, `tests/test_jsonlog.py`
G20	Overdue escalation is **native Rocketlane** (1 day → Project Manager, 4 days → Project Owner), not code — so it works even if this service is down.	Rocketlane Settings → Automations	Configured live; see `ROCKETLANE_SETUP.md`
G21	A phase marked Completed in Rocketlane while its tasks are open is **not** announced to the customer; it and any Blocked task/phase become an internal `tracking` item that clears only when fixed in Rocketlane (no manual resolve).	`services/tracking.py` rule e, `graph/root.py` `ALLOWED["tracking"]`	`tests/test_tracking_flags.py` (`test_phase_marked_completed_with_open_tasks_is_flagged_not_announced`, `test_nothing_about_flags_reaches_the_customer_channel`, `test_flags_are_never_resolved_from_the_dashboard`)